SECURITY-FIRST MCP / JAVA 21

Secure MCP Integration Gateway

A governed sidecar between AI clients and Connector Hub: identity-derived tenancy, least privilege, exact human approval, credential separation and executable attack evidence.

Release candidate 1.0.0-rc.1

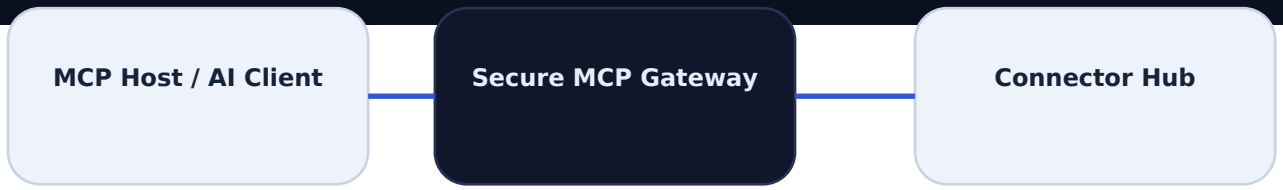
26	40	11	77
Java contracts	HTTP/MCP attacks	release checks	verified total

Prepared 2026-10-12 · Portfolio engineering release

01 / ARCHITECTURE

Authority stays outside the model

Connector Hub executes providers; the gateway owns AI-facing identity, tenant, policy, approval and audit.



- Tenant from verified identity - never a model argument
- Scope-filtered tool discovery + call-time authorization
- Dedicated Connector Hub service credential; no caller-token passthrough
- Fixed upstream paths + HTTPS/host allowlist
- Quotas, approval state and tamper-evident audit

02 / CAPABILITY SURFACE

Small by design

Three reads and one consequential write. No arbitrary SQL. No user-controlled destination.

Tool	Scope	Effect	Approval
orders.lookup	orders:read	Read order	No
inventory.check	inventory:read	Read stock	No
customer.documents.list	documents:read	Permitted docs	No
orders.cancel	orders:cancel	Cancel order	Independent

MCP 2026-07-28 focused subset

server/discover, tools/list, tools/call; per-request metadata; method/name header binding; current result/cache fields; protected-resource metadata. Tool visibility is authorization-sensitive, so tools/list is private-cache scoped.

03 / GOVERNED WRITE

Approval is bound to the exact action

A human approval is not a reusable capability token.

1. Operator/model proposes orders.cancel
2. Gateway canonicalizes business arguments
3. Pending approval stores tenant + requester + tool revision + SHA-256 argument fingerprint
4. Independent same-tenant reviewer approves
5. Execution reconstructs and revalidates every binding field
6. Approval ID becomes upstream idempotency key

TAMPER TEST

Change one character in the approved reason, switch requester/tenant, or change the tool revision: execution fails closed with approval_binding_mismatch.

04 / ADVERSARIAL EVIDENCE

Designed to be attacked

The portfolio signal is not the happy path; it is the denial surface.

PASS	Wrong-audience, expired and tampered tokens
PASS	Cross-tenant order, document and approval access
PASS	Arbitrary SQL and destination/URL injection
PASS	MCP protocol/header/name mismatch
PASS	Self-approval, cross-tenant review and argument tampering
PASS	Duplicate execution and concurrency/idempotency behavior
PASS	Audit-chain integrity and no raw business arguments
PASS	Per-principal/per-tool quota enforcement

05 / RELEASE EVIDENCE

77 deterministic checks passed

Verified locally; additional interoperability gates stay separate.

26	40	11
Java contracts	live HTTP/MCP attacks	repository/release checks

NOT CLAIMED AS LOCALLY PASSED

Native Playwright reviewer-console acceptance; official stable MCP TypeScript v2 client acceptance; deployed Connector Hub provider acceptance. They are included as explicit release gates, not hidden gaps.

06 / DELIVERY

Ready for GitHub review

Standalone sidecar; existing Connector Hub files modified: 0.

- Java 21 source + self-contained synthetic backend
- Connector Hub HTTP adapter with fixed provider mapping
- 40-scenario live attack matrix + Java contracts
- Strict-CSP reviewer console
- English/German technical documentation
- GitHub CI + separate browser/official-SDK release gates
- LinkedIn publication pack and release dossier

Primary references

ts.sdk.modelcontextprotocol.io/v2/

modelcontextprotocol.io/specification/2026-07-28/basic/authorization/security-considerations

github.com/AhadPorkar/connector-hub